

DEVSECOPS & PLATFORM · ISSUE 02 OF 08

Policy as code with OPA.

A policy without a clear error message is a ticket generator.

02

AR

Akhilesh Ranjan Singh

Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

Worth enforcing first

01 No privileged containers

And no host networking or hostPath mounts.

02 Approved registries only

Images come from your registry.

03 Required labels

owner and cost-center on every workload.

04 Requests set, no :latest

Predictable scheduling and rollbacks.



Two enforcement points

1 PR: conf test on manifests

2 Merge

3 GitOps apply

4 Gatekeeper admission

5 Admit or deny + audit

Same Rego in CI and in the cluster. CI gives fast feedback, admission is the backstop.

A readable rule

```
package main

import rego.v1

deny contains msg if {
    some c in input.spec.template.spec.containers
    not startswith(c.image, "acr.example.io/")
    msg := sprintf(
        "%s: use an image from acr.example.io",
        [c.name],
    )
}
```

The message tells the developer how to fix it, not just that they failed.

Rolling out a new policy

1 Audit only

2 Warn

3 Deny with exceptions

4 Deny

Measure violations during audit. Never go straight to deny on a live cluster.

Policy habits

DO

- ✓ Unit-test policies with opa test
- ✓ Write fix instructions in messages
- ✓ Version policies like code

AVOID

- ✗ Deny without remediation text
- ✗ Different rules in CI and cluster
- ✗ Policies nobody on the team can read

KEY TAKEAWAY

Same policy in CI and at admission, with a message that explains the fix.

- Start with four high-value rules
- Audit, warn, then deny
- Test policies like code

YOUR TURN

Which policy would you enforce first on your clusters?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #03 GitOps with Flux and Argo CD

[Save](#) · [Repost](#)